

Fundamentals of Information Systems Security

Lab 9: Incident Response Simulation

A Realistic Cybersecurity Incident Response Exercise

Version: 1.0

Estimated Time: 3-4 Hours

Difficulty Level: Advanced

Prerequisites: All Previous Labs

Contents

1	Introduction	2
1.1	What is Incident Response?	2
1.2	Learning Objectives	2
1.3	Prerequisites	2
1.4	Important Legal Notice	3
2	Incident Response Process Overview	4
2.1	The NIST SP 800-61 Framework	4
2.2	Incident Response Team Roles	4
3	Scenario Overview	5
3.1	The Incident	5
3.2	Lab Setup Requirements	5
3.2.1	Virtual Machines	5
4	Phase 1: Preparation	6
4.1	Exercise 1: Preparation Review	6
5	Phase 2: Detection and Analysis	7
5.1	Exercise 2: Initial Detection and Triage	7
5.2	Exercise 3: Evidence Collection and Analysis	7
5.3	Exercise 4: Network Analysis	7
5.4	Exercise 5: Malware Analysis	8
6	Phase 3: Containment	9
6.1	Exercise 6: System Isolation	9
6.2	Exercise 7: Evidence Preservation	9
7	Phase 4: Eradication and Recovery	10
7.1	Exercise 8: System Restoration	10
8	Phase 5: Post-Incident Activity	11
8.1	Exercise 9: After-Action Review	11
9	Incident Report Template	12
10	Deliverables	12
11	Additional Resources	13

1 Introduction

1.1 What is Incident Response?

Incident response is the structured approach to handling security breaches, cyberattacks, and other security incidents. The goal is to minimize damage, reduce recovery time, and prevent future incidents.

Incident Response Lifecycle (NIST SP 800-61)

1. **Preparation:** Planning, training, and tool deployment
2. **Detection & Analysis:** Identifying and analyzing potential incidents
3. **Containment:** Limiting the scope and impact of the incident
4. **Eradication:** Removing the root cause of the incident
5. **Recovery:** Restoring affected systems to normal operation
6. **Post-Incident Activity:** Lessons learned and improvements

1.2 Learning Objectives

By the end of this lab, you will be able to:

1. Detect and triage a security incident
2. Follow incident response procedures
3. Investigate and analyze security events
4. Contain and eradicate a security incident
5. Recover affected systems and data
6. Document findings and recommendations
7. Apply lessons learned to improve security

1.3 Prerequisites

- Complete knowledge from all previous labs
- Understanding of NIST SP 800-61 (Chapter 4, Chapter 9)
- Familiarity with log analysis and forensic tools
- Basic understanding of Windows and Linux systems

1.4 Important Legal Notice

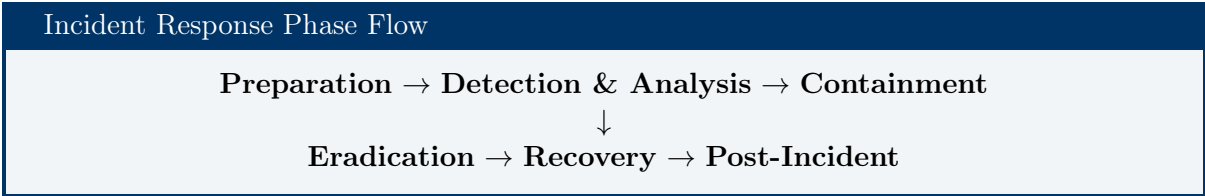
Important Legal Notice

- This simulation is for **educational purposes only**
- All activities are conducted in a controlled lab environment
- Do not replicate these activities on real systems without authorization
- Use the skills learned to improve security defenses

2 Incident Response Process Overview

2.1 The NIST SP 800-61 Framework

NIST Special Publication 800-61 provides comprehensive guidance on incident handling.



2.2 Incident Response Team Roles

highlightblue Role	Responsibilities	Assigned To
Incident Commander	Overall coordination and decision-making	-----
Security Lead	Technical investigation and analysis	-----
Forensics Specialist	Evidence collection and preservation	-----
IT Administrator	System containment and recovery	-----
Legal Counsel	Legal guidance and compliance	-----
Communications Lead	Internal and external communications	-----

3 Scenario Overview

3.1 The Incident

Incident Scenario

Organization: TechSolutions Inc.

Industry: Software Development and IT Services

Employees: 250

Incident Type: Ransomware + Data Exfiltration

Detection: Employee reports suspicious file extensions on shared drives

Timeline:

- 08:00 - Employee in Finance reports encrypted files
- 08:15 - IT Help Desk confirms ransomware is present
- 08:30 - CISO notified, incident response team activated
- 09:00 - Incident response team begins investigation
- 09:30 - Ransomware detected on multiple systems
- 10:00 - Evidence of data exfiltration discovered

3.2 Lab Setup Requirements

3.2.1 Virtual Machines

highlightblue VM	IP Address	Purpose
Kali Linux (Attacker)	192.168.56.101	Simulate attacker activities
Windows 10 (Target)	192.168.56.102	Simulate infected workstation
Windows Server (Do-main)	192.168.56.103	Simulate domain controller
Linux Server (File)	192.168.56.104	Simulate file server

4 Phase 1: Preparation

4.1 Exercise 1: Preparation Review

1. Review the incident response plan:

```
cat IR_Plan_TechSolutions_v2.1.pdf
```

2. Identify available forensic tools:

```
ls /usr/bin/*forensic*  
ls /usr/share/forensics/
```

3. Create an incident response kit:

```
mkdir ~/IR_Kit  
cp /usr/share/forensics/* ~/IR_Kit/
```

4. **Reflection:** What tools would you include in an incident response toolkit?

5 Phase 2: Detection and Analysis

5.1 Exercise 2: Initial Detection and Triage

1. Review the alert:

```
# Ticket #IN-2024-001: Suspicious file extensions reported
# User: jsmith@techsolutions.local
# File: HR_Payroll_July.xlsx.encrypted
```

2. Investigate the reported issue:

```
ssh jsmith@192.168.56.102
find / -name "*.encrypted" 2>/dev/null
find / -name "*README*" 2>/dev/null
```

3. Check for ransomware ransom notes:

```
find / -name "*DECRYPT*" 2>/dev/null
find / -name "*HOWTO*" 2>/dev/null
```

4. **Reflection:** How should you handle a suspected ransomware infection?

5.2 Exercise 3: Evidence Collection and Analysis

1. Collect system logs:

```
# Linux
cp /var/log/syslog ~/evidence/
cp /var/log/auth.log ~/evidence/

# Windows (if available)
wevtutil epl Security security.evtx
wevtutil epl System system.evtx
```

2. Analyze logs for indicators of compromise:

```
grep "Failed password" /var/log/auth.log
grep "ESTABLISHED" /var/log/netstat.log
```

3. Identify attacker activity:

```
sudo grep "sudo" /var/log/auth.log
find / -mtime -1 -type f 2>/dev/null
```

4. **Reflection:** What logs are most important for incident investigation?

5.3 Exercise 4: Network Analysis

1. Analyze network connections:

```
netstat -an | grep ESTABLISHED
ss -tunap | grep -v "127.0.0.1"
```

2. Review firewall logs:

```
sudo iptables -L -n -v
cat /var/log/firewall.log
```

3. **Reflection:** How can network analysis help incident investigation?

5.4 Exercise 5: Malware Analysis

1. Identify ransomware indicators:

```
grep -r "WannaCry" /var/log/*
grep -r "Locky" /var/log/*
find / -name "*.encrypted" -type f
```

2. Check for persistence mechanisms:

```
# Windows: Check startup folder
ls "C:\Users\%USERNAME%\AppData\Roaming\Microsoft\Windows\Start
Menu\Programs\Startup\"

# Windows: Check registry
reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run
```

3. **Reflection:** Why is malware analysis important in incident response?

6 Phase 3: Containment

6.1 Exercise 6: System Isolation

1. Isolate affected systems:

```
# Disconnect from network
ifconfig eth0 down

# Block network access at firewall
iptables -A INPUT -j DROP
iptables -A OUTPUT -j DROP
```

2. Document containment actions:

```
echo "Containment Date: $(date)" >> containment_log.txt
echo "System: 192.168.56.102" >> containment_log.txt
echo "Action: Isolated from network" >> containment_log.txt
```

3. **Reflection:** When should containment be prioritized over eradication?

6.2 Exercise 7: Evidence Preservation

1. Create disk image:

```
dd if=/dev/sda of=evidence_image.dd bs=4096
sha256sum evidence_image.dd > evidence_image.hash
```

2. Document chain of custody:

```
echo "Evidence: evidence_image.dd" >> chain_of_custody.txt
echo "Collected by: $(whoami)" >> chain_of_custody.txt
echo "Date: $(date)" >> chain_of_custody.txt
```

3. **Reflection:** Why is chain of custody important in digital forensics?

7 Phase 4: Eradication and Recovery

7.1 Exercise 8: System Restoration

1. Apply security patches:

```
sudo apt-get update && sudo apt-get upgrade -y
```

2. Restore data from backups:

```
rsync -av /mnt/backups/restore_point/ /var/www/
```

3. Verify system integrity:

```
sha256sum -c file_integrity_manifest.txt
```

4. **Reflection:** What are the RPO and RTO for this incident?

8 Phase 5: Post-Incident Activity

8.1 Exercise 9: After-Action Review

1. Document the incident:

```
cat > incident_report.txt << EOF
INCIDENT REPORT
Incident Number: IR-2024-001
Date: $(date)
Title: Ransomware and Data Exfiltration
Severity: CRITICAL

EXECUTIVE SUMMARY:
[Summarize the incident]

DETAILED FINDINGS:
[Document all findings]

TIMELINE:
[Document incident timeline]

ROOT CAUSE ANALYSIS:
[Identify root causes]

RECOMMENDATIONS:
[List recommendations]
EOF
```

2. Identify root causes:

- -----
- -----
- -----

3. **Reflection:** How can the incident response process be improved?

9 Incident Report Template

Incident Report Format

=====

INCIDENT REPORT

=====

1. INCIDENT OVERVIEW

- Incident Number:
- Date/Time of Discovery:
- Date/Time of Containment:
- Incident Type:
- Severity Level:

2. EXECUTIVE SUMMARY

- Brief description of the incident
- Key findings
- Impact summary
- Recommendations

3. DETAILED ANALYSIS

- Technical findings
- Timeline of events
- Systems affected
- Root cause analysis

4. RESPONSE SUMMARY

- Detection methods
- Containment actions
- Eradication actions
- Recovery actions

5. LESSONS LEARNED

- What worked well
- What could be improved

6. RECOMMENDATIONS

- Short-term improvements
- Long-term improvements

10 Deliverables

Submit a complete incident response report containing:

1. Executive summary of the incident
2. Detailed timeline of events
3. Analysis findings
4. Containment and eradication documentation

5. Recovery verification
6. Root cause analysis
7. Lessons learned
8. Recommendations for improvement
9. Screenshots of key evidence

11 Additional Resources

- **NIST SP 800-61 Rev. 2:** <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>
- **SANS Incident Response:** <https://www.sans.org/incident-response/>
- **OWASP Incident Response:** <https://owasp.org/www-project-incident-response/>